

Traccia:

Durante la lezione teorica, abbiamo visto la Threat Intelligence e gli indicatori di compromissione. Abbiamo visto che gli IOC sono evidenze o eventi di un attacco in corso, oppure già avvenuto. Per l'esercizio pratico di oggi, trovate in allegato una cattura di rete effettuata con Wireshark. Analizzate la cattura attentamente e rispondere ai seguenti quesiti:

Identificare eventuali IOC, ovvero evidenze di attacchi in corso.

In base agli IOC trovati, fate delle ipotesi sui potenziali vettori di attacco utilizzati

Consigliate un'azione per ridurre gli impatti dell'attacco

Identificazione IOC e ipotesi

Analizzando il file con il tool Wireshark notiamo una serie di richieste TCP da parte dell'IP 192.168.200.150. Queste richieste sono fatte da porte inusuali verso porte comuni, ovvero porte di default su cui girano servizi noti (ad esempio le porte 23 del servizio Telnet).

192.168.200.100	192.168.200.150	TCP	74 41304 → 23
192.168.200.100	192.168.200.150	TCP	74 56120 → 111
192.168.200.100	192.168.200.150	TCP	74 33878 → 443
192.168.200.100	192.168.200.150	TCP	74 58636 → 554
192.168.200.100	192.168.200.150	TCP	74 52358 → 135
192.168.200.100	192.168.200.150	TCP	74 46138 → 993
192.168.200.100	192.168.200.150	TCP	74 41182 → 21

Già questo ci fa intuire che c'è una scansione delle porte, magari tramite un tool come nmap. Altro elemento che sembra confermare questa teoria è che, successivamente alla risposta SYN - ACK della macchina target, la macchina attaccante ha inviato un pacchetto RST - ACK, quindi con un reset della connessione che è un tipico comportamento da scansione delle porte.

192.168.200.100	192.168.200.150	TCP	66 41182 → 21 [RST, ACK]
192.168.200.100	192.168.200.150	TCP	66 55656 → 22 [RST, ACK]

Mitigazioni

Per mitigare un tentativo di scansione possiamo usare diverse tecniche. Di seguito un elenco di alcune soluzioni:

Configurare il Firewall in modo tale da bloccare i tentativi di scansione e filtrare gli IP;

Utilizzare un sistema IDS/IPS;

Offuscamento delle porte tramite tecniche come il port knocking e il moving target defense;

Limitare i servizi in esecuzione e disabilitare quelli inutilizzati;

Limitare il tasso di connessioni (Rate Limiting).